

Security and Privacy

1

Information Privacy Regulations And Privacy Impact Assessment

Personally Identifiable Information (PII)

2

- NIST SP 800-122 (*Guide to Protecting the Confidentiality of Personally Identifiable Information*) defines PII as:

“Any information about an individual maintained by an agency, including
(1) any information that can be used to distinguish or trace an individual’s identity, such as name, social security number, date and place of birth, mother’s maiden name, or biometric records; and
(2) any other information that is linked or linkable to an individual, such as medical, educational, financial, and employment information”

Personal Data

3

- *Personal data*, is used in the General Data Protection Regulation (GDPR), which was issued by the European Union (EU) and came into force in May 2018
- The GDPR defines *personal data* as:

“Any information relating to an identified or identifiable natural person (“data subject”); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person”

European Union GDPR

4

- A number of national governments have introduced laws and regulations intended to protect individual privacy in information processing
- One of the most comprehensive initiatives is the European Union (EU) General Data Protection Regulation (GDPR), approved by the EU Parliament in 2016
- The GDPR is designed to:
 - Harmonize data privacy laws across Europe
 - Protect and empower the data privacy of all EU citizens
 - Reshape the way organizations, both public and private, across the region approach data privacy
- Important aspects of GDPR that organizations that do business in Europe need to be aware of are listed on the following slide

GDPR

5

- Applies to all companies worldwide that process personal data of EU residents
- Widens the definition of personal data compared to prior regulations by EU member states
- Tightens the rules for obtaining valid consent to using personal information
- Requires public authorities processing personal information to appoint a data protection officer (DPO), as well as other entities, when core activities require regular and systematic monitoring of data subjects on a large scale or consist of processing on a large scale of special categories of data
- Mandates data protection impact assessments
- Requires organizations to notify the local data protection authority of a data breach within 72 hours of discovering it
- Introduces the right to be forgotten
- Requires that privacy be included in systems and processes by design

Examples of PII



- **Government-issued identification**
 - For example, driver's license, passport, birth certificate, and pension and medical benefits identifiers (e.g., in the United States, Social Security number and Medicare number)
- **Contact information**
 - For example, email address, physical address, and telephone numbers
- **Online information**
 - For example, Facebook and other social media identifiers, passwords, and PINs (personal identification numbers)
- **Geolocation data**
 - From smartphones, GPS devices, and cameras
- **Device address**
 - Such as an IP address of a device connected to the Internet or the media access control (MAC) address of a device connected to a local area network
- **Verification data**
 - For example, mother's maiden name, pets' and children's names, and high school
- **Medical records information**
 - Such as prescriptions, medical records, exams, and medical images
- **Biometric and genetic information**
 - Such as fingerprints, retinal scans, and DNA
- **Account numbers**
 - Such as bank, insurance, investment, and debit/credit cards

Sensitivity of PII

8

Although organizations have a duty to protect all PII, both as a matter of policy and regulatory requirement, they frequently make a distinction between sensitive PII and non-sensitive PII

The International Association of Privacy Professionals (IAPP) proposes the following somewhat general definition:

“Data which is more significantly related to the notion of a reasonable expectation of privacy, such as medical or financial information”

The *OECD Privacy Framework* document states that “it is probably not possible to identify a set of data which are universally regarded as being sensitive”

The U.S. Commerce Department defines *sensitive PII* as “PII which if lost, compromised, or disclosed without authorization, could result in harm, embarrassment, inconvenience, or unfairness to an individual”

- The document lists the following types of PII as sensitive when associated with an individual:
 - Social Security number (including in truncated form)
 - Place of birth
 - Date of birth
 - Mother’s maiden name
 - Biometric information
 - Medical information (excluding brief references to absences from work)
 - Personal financial information
 - Credit card/purchase card account numbers
 - Passport numbers
 - Potentially sensitive employment information (e.g., performance ratings, disciplinary actions, results of background investigations)
 - Criminal history
 - Information that may stigmatize or adversely affect an individual

Non-Sensitive PII

9

- Examples of non-sensitive PII include an individual’s name, work email address, work address, and work phone number
- PII that might not include elements normally identified as sensitive may still be sensitive and require special handling if its compromise could cause substantial harm, inconvenience, embarrassment, or unfairness to an individual
- The U.S. Homeland Security Department provides the following examples in the *Handbook for Safeguarding Sensitive PII*:
- A collection of names is not SPII if it is a list, file, query result of:
 - Attendees at a public meeting
 - Stakeholders who subscribe to a DHS email distribution list
- It is SPII if it is a list, file, query result of:
 - Law enforcement personnel, such as investigators, agents, or support personnel
 - Employee performance ratings
 - Employees with overdue mandatory training course completions

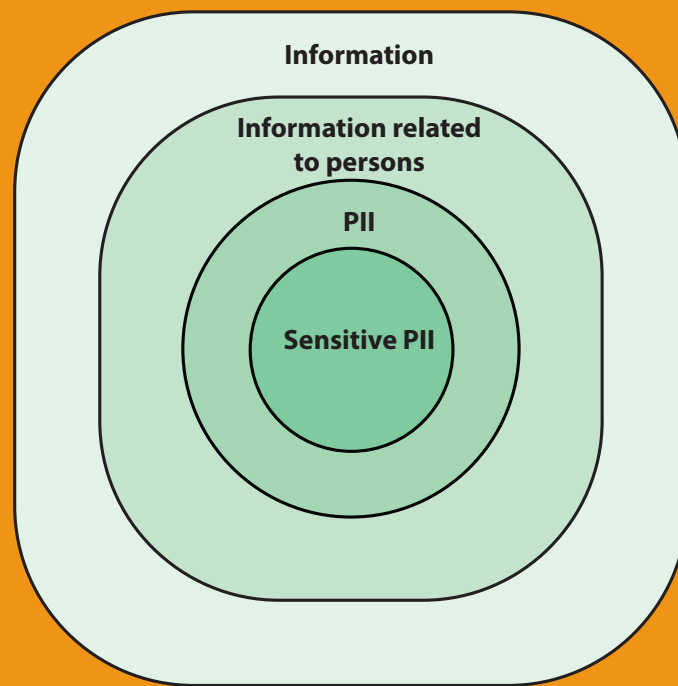


Figure 3.1 Information and PII

De-identification/Anonymization

- **De-identification of data**

- The process of removing or obscuring any personally identifiable information from individual records in a way that minimizes the risk of unintended disclosure of the identity of individuals and information about them

- **Anonymization of data**

- The process of data de-identification that produces data where individual records cannot be linked back to an original, as they do not include the required translation variables to do so
- A code or other means of association for re-identification does not exist
- Anonymization is commonly used by government agencies to release datasets to the public for research purposes
- It is also useful for system testing
- Robust testing involves simulating real conditions as closely as possible, and so should it involve testing real-world data
- Because of the processing and operational burdens involved in protecting PII, it is more efficient to work with an anonymized dataset

Re-identification

12

- *Re-identification*

- A process that reestablishes the relationship between personally identifiable data and de-identified data
 - The organization can achieve this by using a code, an algorithm, or a pseudonym that is assigned to individual records, with the enabling information protected by encryption or other means
 - Another approach is to encrypt identifying elements within data records
-
- There is, however, a risk that an adversary can re-identify data records by making use of publicly available information to deduce the identity associated with an individual data record

13

Table 3.1 Example of Privacy Risk Using Aggregation Techniques

Performance	Students
Below grade level	30-39
At grade level	50-59
Above grade level	20-29

(a) Totals before new student enrolls

Performance	Students
Below grade level	30-39
At grade level	50-59
Above grade level	30-39

(b) Totals after new student enrolls

Table (b) shows the results when the table is republished after a new student enrolls. By comparing the two tables, one can readily infer that the student who joined the school is performing above grade level.

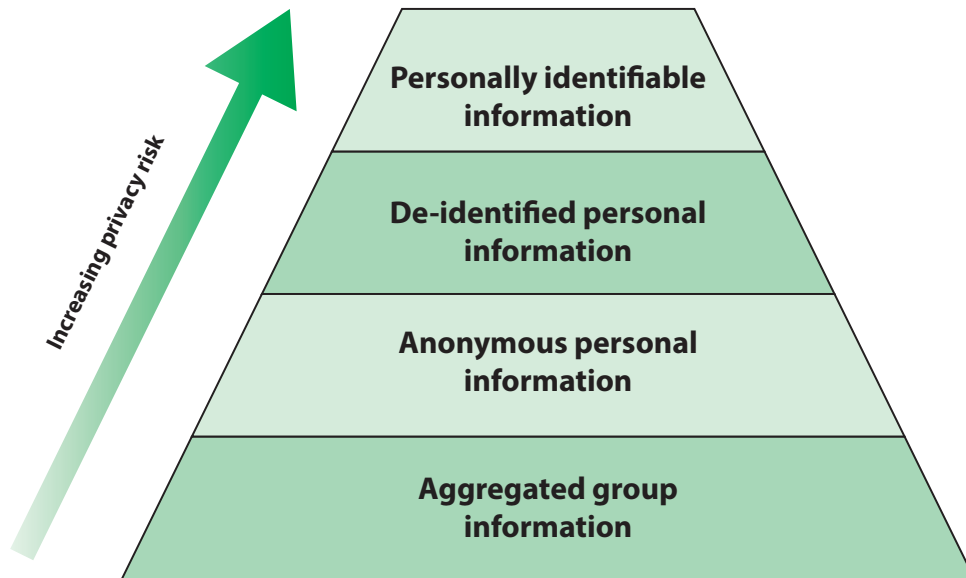


Figure 3.2 Degrees of Privacy Risk

De-identification and Anonymization

- Two terms that are commonly used in describing the obfuscation of PII for privacy purposes are *de-identification* and *anonymization*
- The context for both de-identification and anonymization is the following:

“An organization collects PII on a group of individuals and stores it as a file of records, one per individual, often referred to as a *dataset*.

Then, if the organization wants to use that dataset for an application or applications that do not require individual identification, the objective is to retain useful data while concealing information that identifies individuals and/or reducing the extent to which identifying information is able to be associated with individuals”

Anonymization of PII has the following characteristics for each individual in the group:

The remaining data do not suffice to associate identifying data to the PII principals to whom they relate

An adversary cannot recover personal identities from the anonymized data by reasonable efforts

NISTIR 8053 (*De-Identification of Personal Information*), illustrates the de-identification or anonymization process

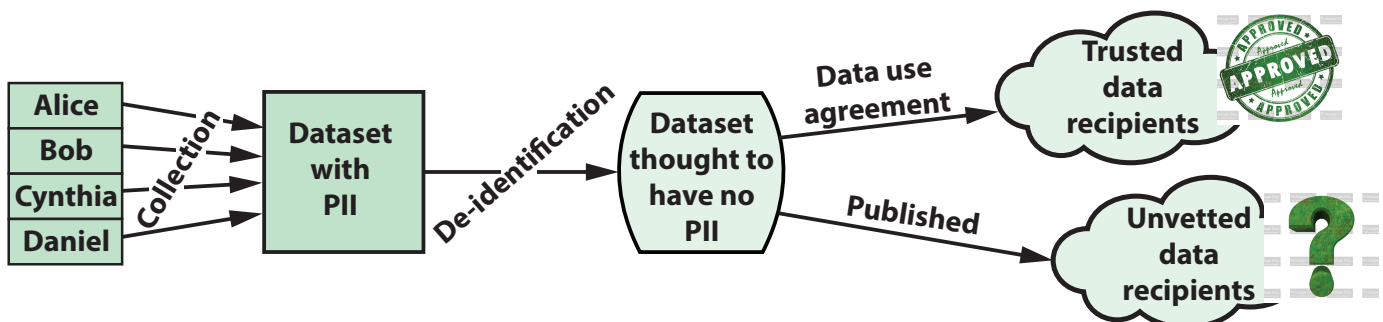


Figure 7.1 Data Collection, De-identification, and Use

Re-Identification Attacks

18

- The document *Concerning the Re-Identification of Consumer Information*, from the Electronic Privacy Information Center documents a number of examples of re-identification of de-identified or anonymized data, including the following:
 - **Netflix study***
 - Netflix publicly released 100 million records regarding how its users had rated movies over a six-year period
 - Even though identifying user-names were removed and each user was given a unique identifying number, researchers found that it was relatively easy to re-identify the individuals
 - **AOL's release of user data***
 - In 2006, America Online (AOL) publicly posted 20 million search queries for 650,000 AOL search engine users
 - Before the data were released, AOL anonymized it by removing identifying information
 - Even though the data were anonymized before the release, within a relatively short time, journalists were able to trace user queries to specific individuals

19

Table 7.4 Examples of Direct Identifiers and Quasi-Identifiers

Direct identifiers		Quasi-identifiers			Other attributes			
Name	Address	Birthday	Postal code	Sex	Weight	Diagnosis	...	...

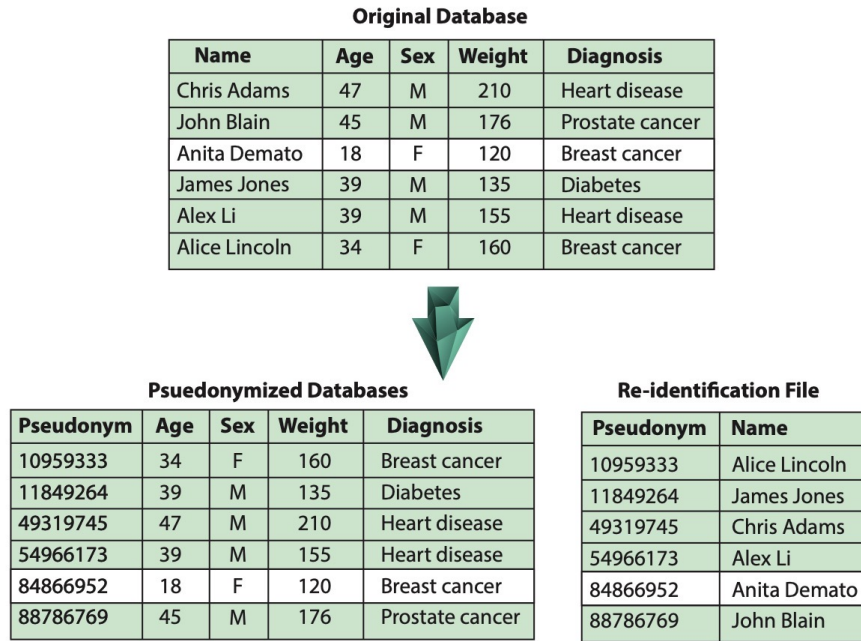


Figure 7.5 Pseudonymization

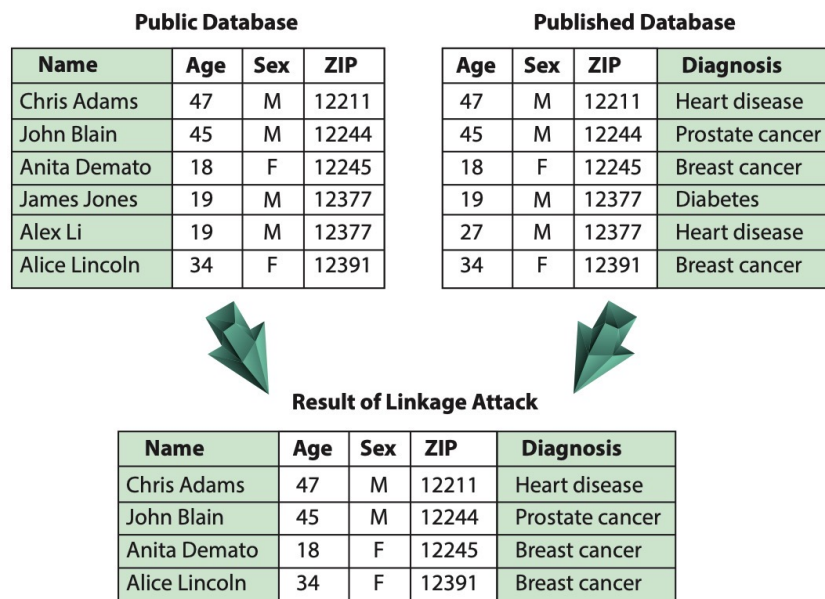
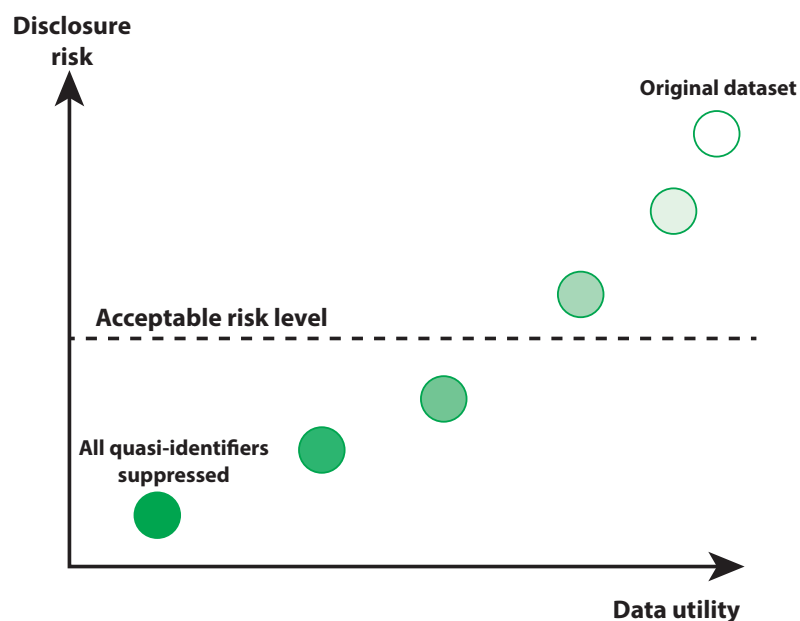
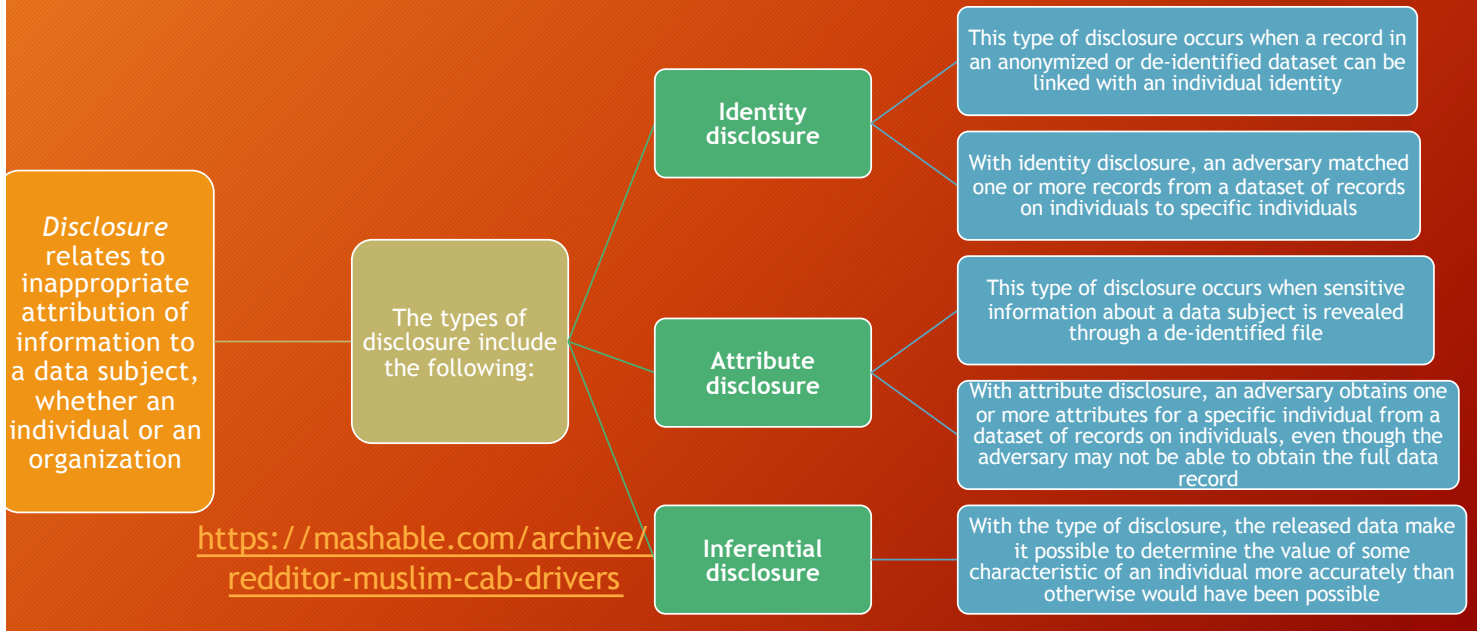


Figure 7.7 Linkage Attack Example

Disclosure Risks

22



23

Figure 7.8 Disclosure Risk versus Data Utility

Risk Management and Privacy Impact Assessment

Risk Assessment

- The ultimate objective of risk assessment is to enable organization executives to determine an appropriate budget for security and, within that budget, implement security controls to optimize the level of protection
- This objective is met by providing an estimate of the potential cost to the organization of security breaches, coupled with an estimation of the likelihood of such breaches
 - If the scale of such an effort is too ambitious, projects may be large, complicated, and unreviewable projects, and there may be an incentive to leave out things that are not easily quantified
 - On the other hand, if effective ways of calculating risk are not employed, managers tend to underestimate the magnitude of the risk and may choose to invest in other areas that they understand better and that will lead to clear payoffs
- Responsible executives need to develop a plan for risk assessment that is balanced between too much and too little

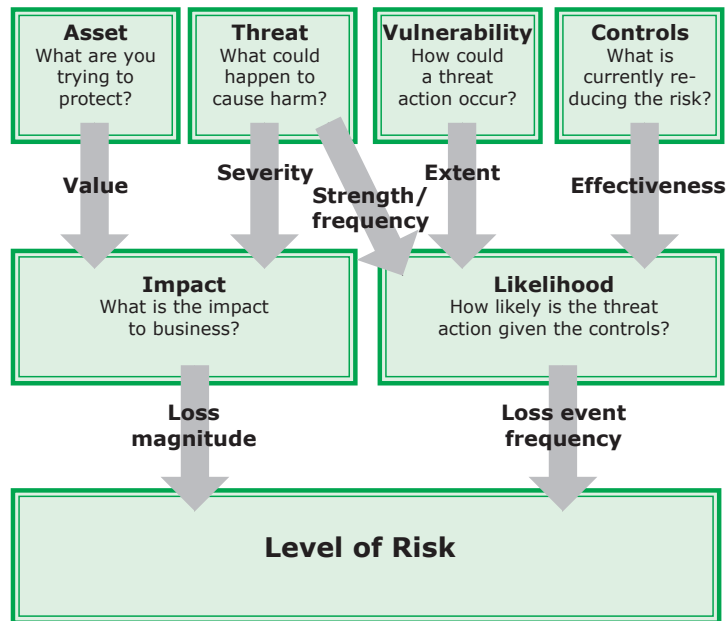


Figure 11.1 Determining Information Security Risk

Qualitative Risk Assessment

- FIPS 199 (*Standards for Security Categorization of Federal Information and Information Systems*) defines three security categories, based on the potential impact on an organization should certain events occur that jeopardize the IT assets needed by the organization to accomplish its assigned mission, protect its assets, fulfill its legal responsibilities, maintain its day-to-day functions, and protect individuals
- The categories are:
 - **Low:** Expected to have a limited adverse effect on organizational operation, organizational assets, or individuals. This might:
 - Cause a degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the functions is noticeably reduced
 - Result in minor damage to organizational assets
 - Result in minor financial loss
 - Result in minor harm to individuals
 - **Moderate or medium:** Expected to have a serious adverse effect on organizational operations, organizational assets, or individuals. This might:
 - Cause a significant degradation in mission capability to an extent and duration that the organization is able to perform its primary functions, but the effectiveness of the function is significantly reduced
 - Result in significant damage to organizational assets
 - Result in significant financial loss
 - Result in significant harm to individuals that does not involve loss of life or serious life threatening injuries
 - **High:** Expected to have a severe or catastrophic adverse effect on organizational operations, organizational assets, or individuals. This might:
 - Cause a severe degradation in or loss of mission capability to an extent and duration that the organization is not able to perform one or more of its primary functions
 - Result in major damage to organizational assets
 - Result in major financial loss
 - Result in severe or catastrophic harm to individuals involving loss of life or serious life threatening injuries

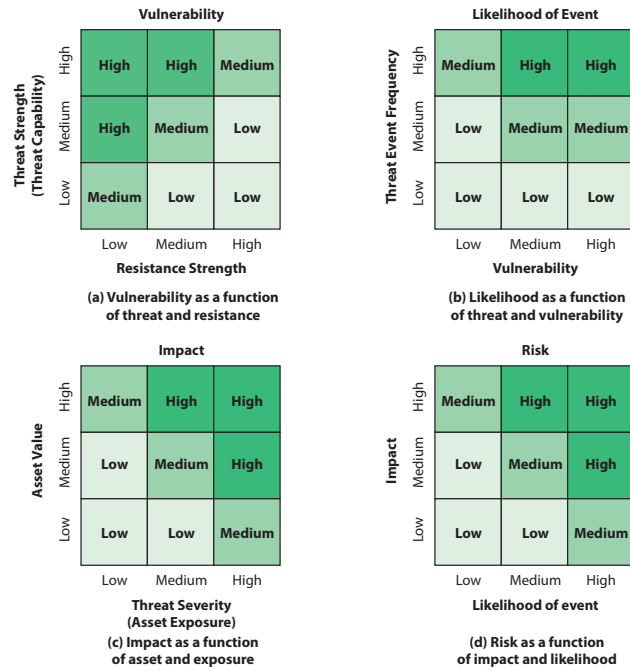


Figure 11.3 Qualitative Risk Determination

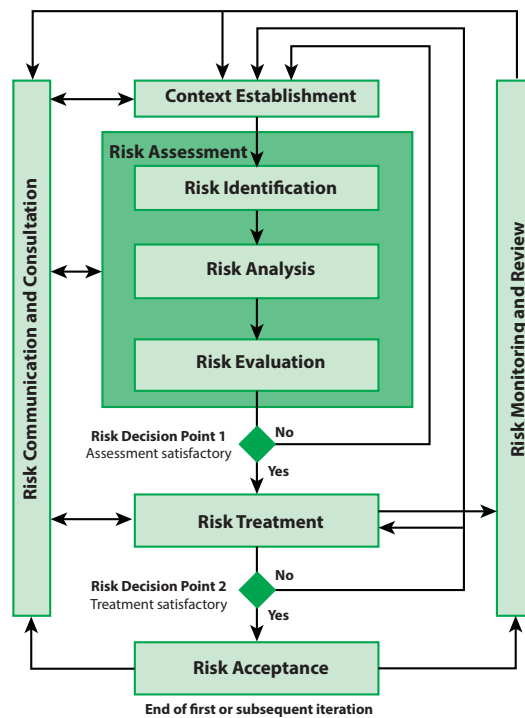


Figure 11.5 ISO 27005 Risk Management Process

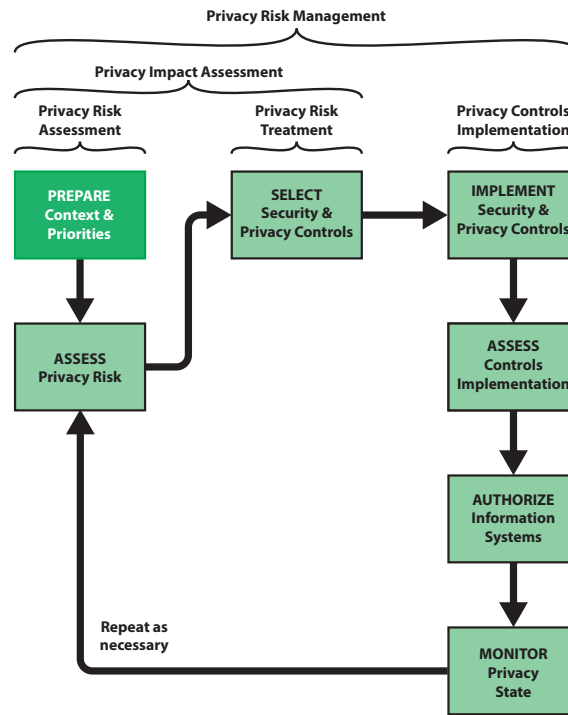


Figure 11.7 Privacy Risk Management Framework

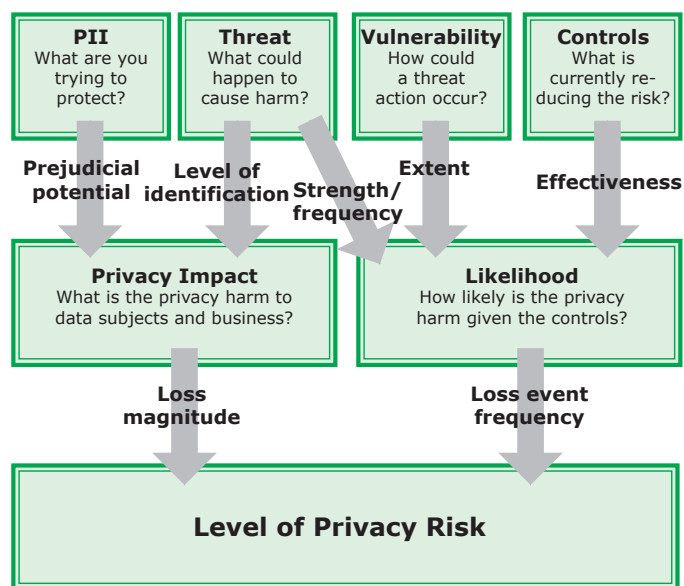


Figure 11.8 Determining Privacy Risk

Assessment of Privacy Impact

32

A typical approach to estimating privacy impact is to look at the two factors that contribute to the impact:

Prejudicial potential:

An estimation of how much damage would be caused by all the potential consequences of a threat

Level of identification:

An estimation of how easy it is to identify data subjects with the available data processed by the available software

Table 11.3 Definition of Privacy Impact Levels

Impact	Impact on PII principals	Impact on organization
Very low	Virtually no noticeable impact	Virtually no noticeable impact
Low	Negligible economic loss; or small, temporary reduction of reputation, or no impact on other personal factors	No violation of law or regulation; or negligible economic loss; or small, temporary reduction of reputation.
Moderate	Economic loss that can be restored; or small reduction of reputation or at most minor impact other personal factors	Minor violation of law or regulation resulting in warning; or economic loss which can be restored; or some reduction of reputation.
High	Large economic loss that cannot be restored; or serious loss of reputation or other psychological damage by revealing sensitive information; or serious impact on other personal factors.	Violation of law or regulation resulting in fine or minor penalty; or large economic loss that cannot be restored; or serious and long-lasting loss of reputation.
Very high	Considerable economic loss that cannot be restored; or serious loss of reputation or other psychological damage with long-lasting or permanent consequences; or serious impact on other personal factors.	Serious violation of law or regulation resulting in substantial fine or other penalty; or considerable economic loss that cannot be restored; or devastating and long-lasting loss of reputation.

33

Likelihood

34

- NISTIR 8062 defines *likelihood* in privacy risk assessment as the estimated probability that a threat action will occur and be problematic for a representative or typical individual whose PII is processed by the system
 - This is a complex issue that involves assessing the following four factors:
 - The probability that a threat action will be attempted, either intentionally or unintentionally
 - The capability of the threat agent to perform the threat event
 - The vulnerabilities in the system that would enable the attempted threat action to occur
 - The reduction in probability due to the effectiveness of existing or planned security and privacy controls
- As with impact assessment, the risk analyst can use a five-level scale for each of these factors

Assessing Privacy Risk

35

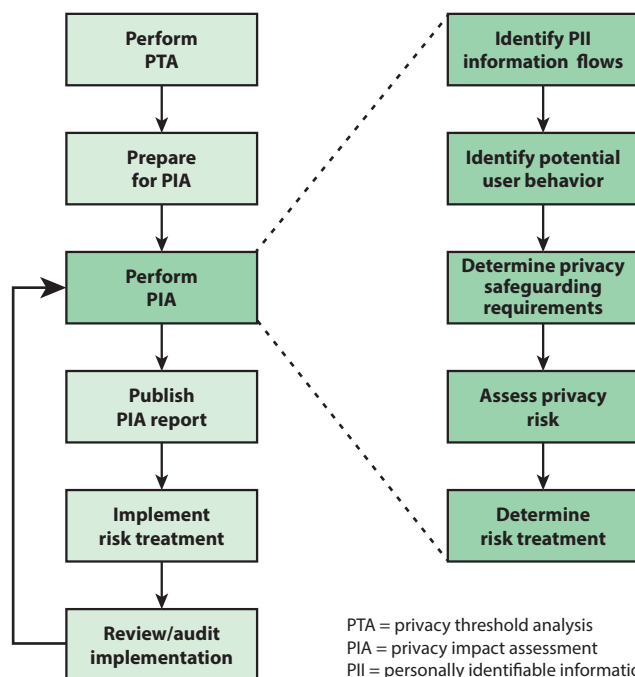
- Privacy risk assessment is based on an estimate of impact and of likelihood
 - An organization should carry out this assessment for each primary asset (PII stored on a system) and each threat category
- For each primary asset and threat category, the organization should set a priority, based on where the risk is located in the matrix and on the risk criteria used by the organization
- The following are typical guidelines for the five risk levels:
 - **Very high**
 - These risks must be absolutely avoided or significantly reduced by implementing controls that reduce both their impact and likelihood
 - **High**
 - These risks should be avoided or reduced by implementing controls that reduce the impact and/or likelihood, as appropriate
 - **Moderate**
 - The approach for moderate risk is essentially the same as for high risk, the difference is that moderate risks are of lesser priority, and the organization may choose to devote fewer resources to addressing them
 - **Low**
 - The organization may be willing to accept these risks without further control implementation
 - **Very low**
 - The organization may be willing to accept these risks because further attempts at reduction would not be cost-effective

		Risk				
Impact	VH	M	H	VH	VH	VH
	H	L	M	H	VH	VH
	M	VL	L	M	H	VH
	L	VL	VL	L	M	H
	VL	VL	VL	VL	L	M
		VL	L	M	H	VH
		Likelihood of Event				

		Risk				
Impact	VH	VH	VH	VH	VH	VH
	H	H	H	H	H	VH
	M	M	M	M	H	VH
	L	L	L	M	H	VH
	VL	VL	L	M	H	VH
		VL	L	M	H	VH
		Likelihood of Event				

36

Figure 11.9 Two Example of Privacy Risk Matrices



37

Figure 11.10 ISO 29134 PIA Process

The EU General Data Protection Regulation

- GDPR is a European Commission regulation for the protection of data in the European Union (EU)
- The European Commission published the GDPR on April 27, 2016, and it entered into force on May 25, 2018
- The GDPR builds on the foundations of and repeals its predecessor, Directive 95/46/EC, which had provided the basis for EU member states' data protection laws
- The GDPR is enforceable in all the nations in the European Economic Area (EEA), which consists of the 28 member states of the EU, plus Iceland, Liechtenstein, and Norway
- The GDPR also regulates the flow of personal data outside the EU
- Its main objective is to protect the privacy of citizens of the EU and unify the data regulation rules of the EU's member nations
- Its rules apply to private organizations and government agencies, including the police and military
- Mandates in the GDPR apply to all personal data of EU citizens, whether or not the organization collecting the data in question is located within the EU, as well as all people whose data is stored within the EU, whether or not they are actually EU citizens

Structure of the GDPR

39

- The GDPR consists of a set of 99 articles, organized into 11 chapters
- These 99 articles are the specific rules put forth in the regulation
- In addition, the GDPR document includes 173 recitals, which provide commentary and additional explanation of the GDPR
- Each recital, with the exception of recital 172, is associated with one or more specific articles
- In the English-language version of the regulation, the articles occupy 57 pages, and the recitals occupy 31 pages

GDPR Objectives

- Provide the fundamental right to the protection of personal data for every individual
- Harmonize the protection of fundamental rights and freedoms of natural persons in respect of processing activities and to ensure the free flow of personal data between member states
- Balance privacy rights against other fundamental rights, in accordance with the principle of proportionality
- Define a strong and more coherent data protection framework in the EU, backed by strong enforcement, given the importance of creating the trust that will allow the digital economy to develop across the internal market
- Enable, to the extent possible, natural persons to have control of their own personal data
- Ensure consistent and homogenous application of the rules for the protection of the fundamental rights and freedoms of natural persons with regard to the processing of personal data throughout the European Union
- Strengthening and setting out in detail the rights of data subjects and the obligations of those who process and determine the processing of personal data, as well as equivalent powers for monitoring and ensuring compliance with the rules for the protection of personal data and equivalent sanctions for infringements in the member states
- Take account of the specific needs of micro, small, and medium-sized enterprises in the application of the GDPR

Security of Processing

41

- Article 5 mandates that personal data shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage
- This principle is further incorporated in Article 32, which mandates the implementation of appropriate technical and organizational measures to ensure a level of security appropriate to the risk
- Article 32 lists the following specific measures:
 - The pseudonymization (upcoming classes) and encryption of personal data
 - The ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services (previous classes)
 - The ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident
 - A process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures for ensuring the security of the processing (this class)

General Data Protection Regulation

42

- The EU General Data Protection Regulation (GDPR) describes a *privacy impact assessment (PIA)* in the following terms:

“Where a type of processing in particular using new technologies, and taking into account the nature, scope, context and purposes of the processing, is likely to result in a high risk to the rights and freedoms of natural persons, the controller shall, prior to the processing, carry out an assessment of the impact of the envisaged processing operations on the protection of personal data. A single assessment may address a set of similar processing operations that present similar high risks”

General Data Protection Regulation

43

- The GDPR mandates that a PIA include:
 - A systematic description of the envisaged processing operations and the purposes of the processing, including, where applicable, the legitimate interest pursued by the controller
 - An assessment of the necessity and proportionality of the processing operations in relation to the purposes
 - An assessment of the risks to the rights and freedoms of data subjects
 - The measures envisaged to address the risks, including safeguards, security measures, and mechanisms to ensure the protection of personal data and to demonstrate compliance with the GDPR, taking into account the rights and legitimate interests of data subjects and other persons concerned

Data Protection Impact Assessment (DPIA)

44

- The GDPR frequently uses the term *risk* - types of risks to be considered:
“to the rights and freedoms of natural persons, of varying likelihood and severity, which may result from personal data processing and could lead to physical, material, or non-material damage”
- A risk can become high risk, depending on the likelihood and severity of the risk as determined in a risk assessment process by reference to the nature, scope, context, and purpose of processing
- Article 35 mandates the use of a DPIA for risk assessment and treatment

Preparing for a PIA

45

The important components of PIA preparation are:

Identify the PIA team and provide it with direction

Prepare a PIA

Describe the system or project that is the subject of this PIA

Identify stakeholders

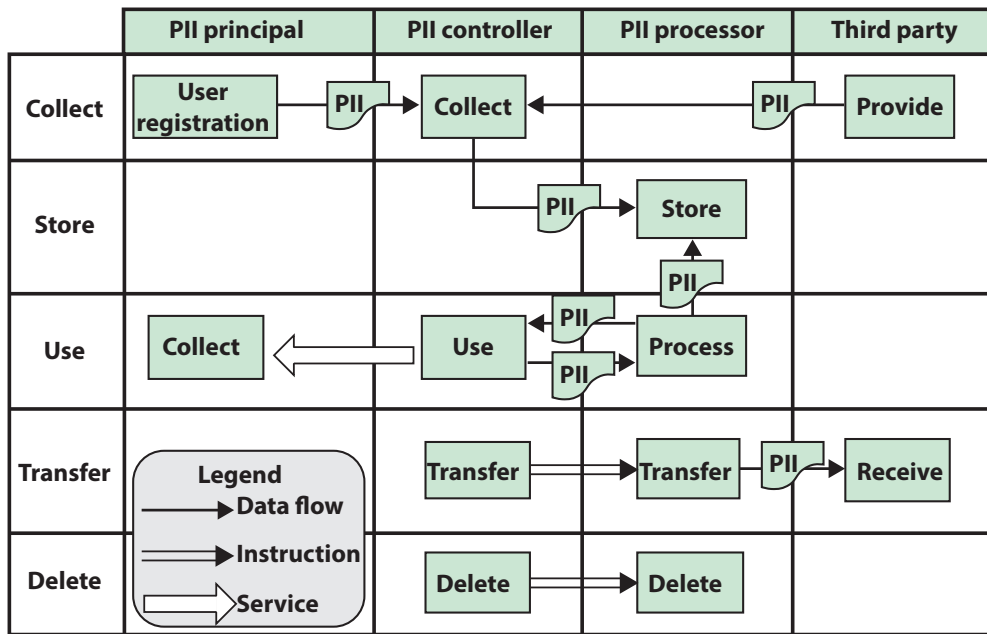


Figure 11.11 Workflow Diagram of PII Processing

PIA Team / Stakeholders

- PII principal/data subject - User
- PII controller - Entity/person that determines the purposes and means of processing personal data
- PII processor - Entity/person responsible for processing personal data in accordance with the instructions of a controller
- Third party - Entity/person who, under the direct authority of the controller or processor, are authorized to process personal data

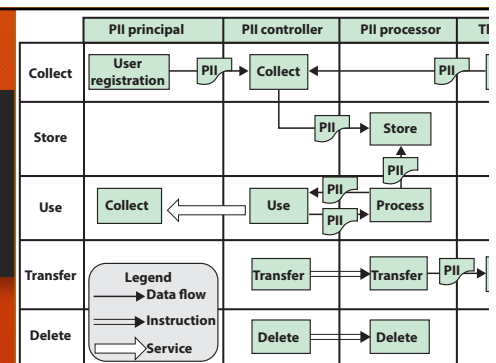


Figure 11.11 Workflow Diagram of PII Processing

Assess Privacy Risk

48

Privacy risk assessment has three steps:

Risk identification

The assessor identifies the potential threats and the system vulnerabilities that are applicable to this case

Risk analysis

The assessor calculates the level of risk for each potential impact

Risk evaluation

The assessor determines the relative prioritization of privacy risk, based on the severity of privacy impact on PII principals as well as the overall impact to the organization

Determine Risk Treatment

49

The final step of the PIA is to determine what risk treatments will be applied to the identified risks

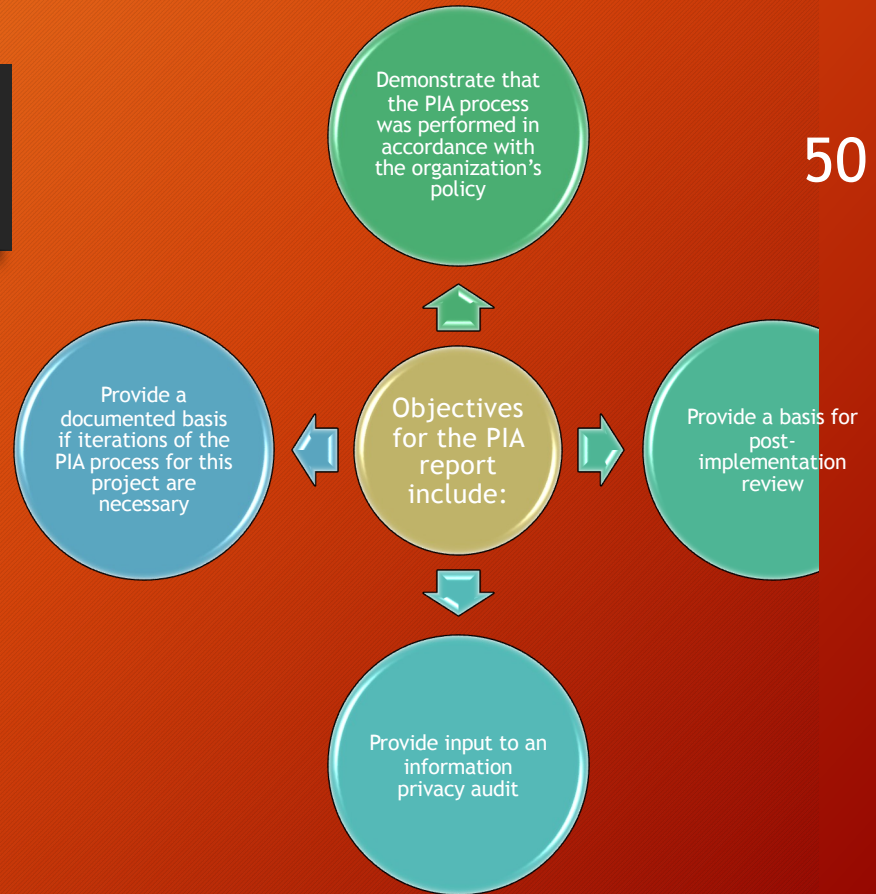


This involves three tasks:

- Choose treatment options
- Determine controls
- Create risk treatment plans

The PIA Report

50



Quiz time!

51



Go to wooclap.com

Enter the event code in the top banner

Event code

COSIY

Assignment 2: Privacy Impact Assessment

51

COP-MODE project: Context-aware Privacy
Protection for Mobile Devices

<https://cop-mode.dei.uc.pt/>

Assignment 2: Privacy Impact Assessment (PIA)

1. Investigate the steps and methodology to carry out a PIA
2. Perform a (simplified) PIA by applying relevant methodologies identified in the previous step
3. PIA shall be performed for the setup of a real-world project (COP-MODE) that required data collection campaigns from users

Steps:

1. Study related literature/guidelines to understand the concepts and steps of a methodology to perform a PIA
 2. Select a tool for performing PIA and/or study examples of PIA reports that can serve as a reference
 3. Perform the PIA and document your analysis
 4. Submit the report in moodle (deadline May 10)
-

The Problem of Privacy in Mobile Devices



Dozens of apps

X



Multiple Configurations

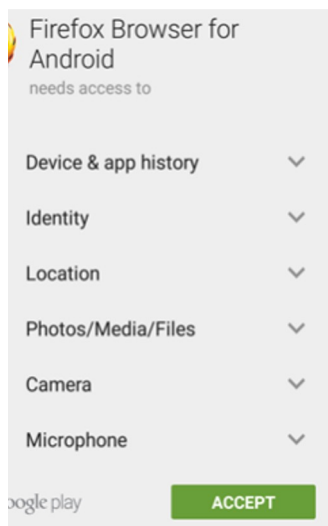
=



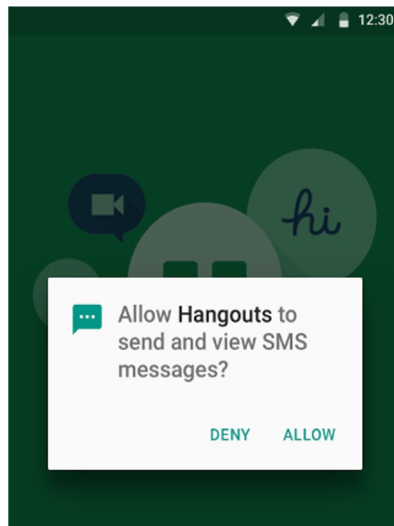
Privacy Loss

Privacy in Mobile Devices

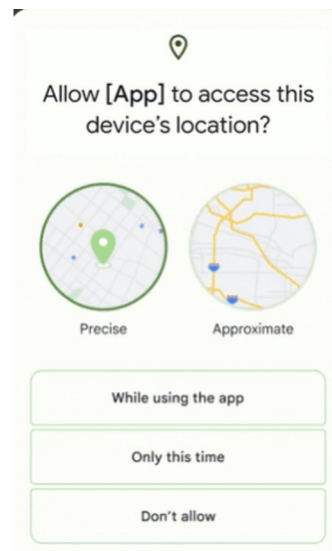
Install-time Permissions



Runtime Permissions (Oct 2015)

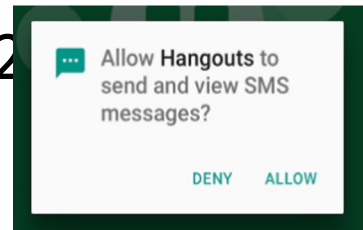


Latest Improvements



- Location Obfuscation
- “While using the app” (location, camera, microphone)
- “Only this time”
- Auto-reset when unused

Privacy in Mobile Devices (2)



Runtime permissions allow:

- fine-grained permissions control
- to contextualize permission prompts by the needs of the app

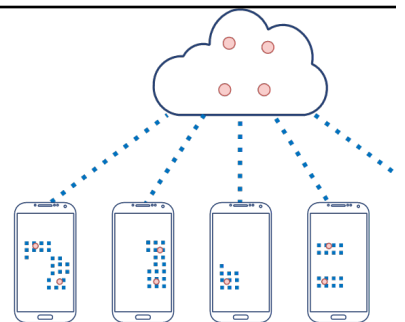
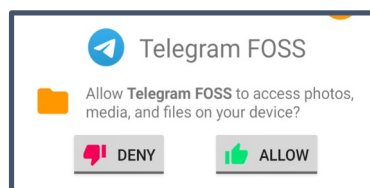
The problem: (hundreds of daily) **automatically accepted permissions**

- **Violate** contextual integrity (preferences of user within context)
- **Contradict** user expectations

Solution: Automated Privacy Decisions

- Several devices with local info on:

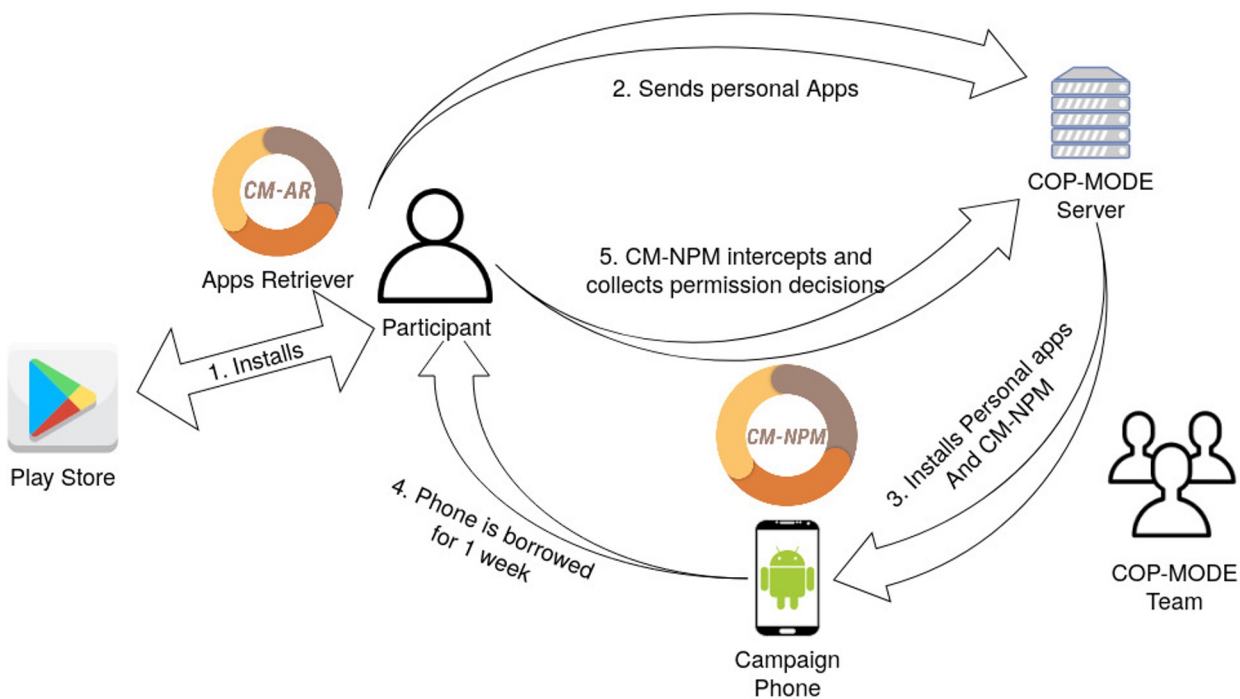
- Requesting Application
- Permission
- Grant Decision



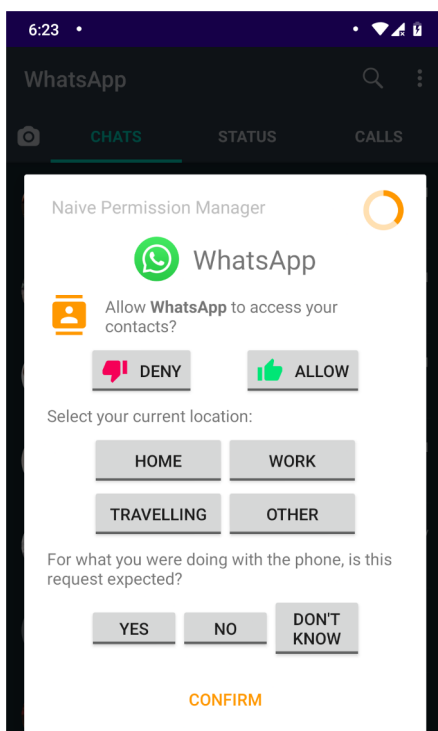
- Prediction of Grant Decisions (**Allow** / **Deny**)
- According to Users' Preferences

For this, we need data!

COP-MODE: Data Gathering Campaigns



COP-MODE: Data Gathering Campaigns (2)



Collected data (summarized):

- **Requesting application:** name and play store category
- **Permission:** name, group and grant result (allow/deny)
- **Phone state:** geolocation, network connection, plug, dock, call and screen state, and apps running in the foreground/background
- **User context:** time, semantic location and if the user is in an event, according to their calendar.
- **Expectancy:** answer to "For what you were doing with the phone, is this request expected?"

<https://cop-mode.dei.uc.pt/dataset>

<https://cop-mode.dei.uc.pt/cm-npm>

COP-MODE: Data Gathering

93 participants

- 64.5% were students
- 71% were between 18 and 24 years old
- 57% with an IT background (studying or professionals)

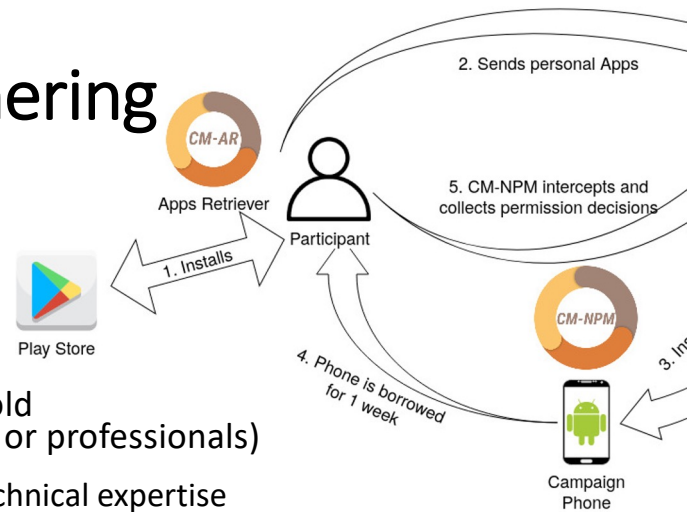
→ Biased data towards young adults with technical expertise

Using our smartphones for 1 week+

Collected answers to 2M+ permission requests

65K+ manually answered requests

(~837/day, ~35/hour)



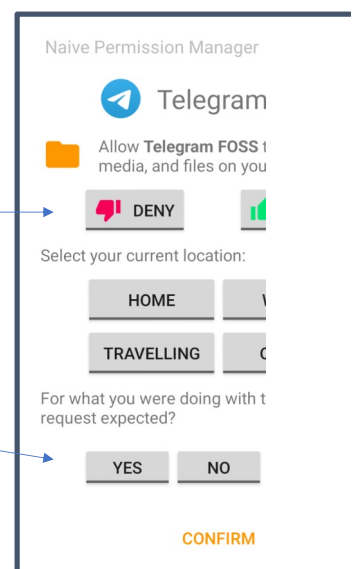
<https://cop-mode.dei.uc.pt/campaigns>

COP-MODE Data: Main Findings

- Avg 836 requests/day/user, nearly 35/hour

65K+ manually answered permission requests:

- Nearly 50% requests unexpected to users
- 15% privacy violations



To catch 15% privacy violations ► answer 35 requests/hour

[Mendes et al., "Effect of User Expectation on Mobile App Privacy: A Field Study", PerCom'22]

Assignment 2: Privacy Impact Assessment (PIA)

1. Describe/characterize the system setup that is the subject of this PIA
2. Initial risk assessment for a plain setup without any corrective measures
3. A plan of action (corrective measures) to address the identified risks (based on knowledge you obtained so far in the course – crypto, network security)

Risk	Mitigation
Data leak through eavesdropping of communications between smartphones and the project server.	<i>TBD - your mitigations</i>
Data leak from unauthorized server/data access. Access to the stored data should be limited to authorized users and the server should be accessible remotely, but not exposed/accessible directly to from the outside.	<i>TBD - your mitigations</i>
Data at rest linkage. The data in the server should not be linkable to an individual by third parties. I.e. the email address must be protected (not clear text), but the PII collector/processor must still be able to link it to the data in the server (e.g. for deletion in case the participant requests it).	<i>TBD - your mitigations</i>
Sensitive information leakage, in particular the names of the applications that are collected. It is required to know that a given application was used and is the same for the several entries that are collected, but the names of the applications should not be present in the server in raw format.	<i>TBD - your mitigations</i>
